

Authorities Side — Map-First Native App & Login

A separate native Android app for officials, centred on a live map of reported issues, gated by a simple login.

Context

The citizen native Android app is done and verified on-device over WiFi. The authorities side is the next build, and three things are settled:

- **Centrepiece:** a map view with **pins on reported locations** ("red pin points of the reported area").
- **Delivery:** a **separate native Android app** (its own icon/name), parallel to the citizen app.
- **Access:** a **simple authorities login**.

Key finding from exploring the code: a working officials **web** surface already exists at `/officials/*` — a triage dashboard, a live Google map (`official_map.js` already draws urgency markers + a heatmap and opens a detail/status modal), and a ward planning view. All served by the same Flask server, mobile-responsive, but with **no authentication**. So this work is mostly: (1) make the map the front door and turn markers into pins, (2) add a login gate, (3) package a second Capacitor app pointed at `/officials/`. We reuse the existing map JS, detail modal, and `/api` endpoints rather than building new.

Biggest risk — the Google Maps key. It may be HTTP-referrer-restricted to `localhost`, in which case the map loads on a desktop but goes **blank inside the app** (the WebView's referrer is the LAN IP). This is checked and fixed first.

Phase 0 — De-risk the Maps key (do first)

The officials map loads in-WebView via `templates/official/map_view.html` → `maps.googleapis.com/maps/api/js`. Inside the app the `Referer` is `http://192.168.1.5:5000/...`, not `localhost`.

- Confirm the map renders today: open `http://localhost:5000/officials/map` in a desktop browser; expect urgency markers + heatmap over Kolkata.
- **User action (Google Cloud Console → Credentials → the Maps key):** under *Application restrictions* → *HTTP referrers*, add `http://192.168.1.5:5000/*` (and `http://192.168.1.5/*`), keeping `localhost:*`; or set restrictions to **None** for the demo. Confirm "Maps JavaScript API" is enabled and billing is active.
- Optional hardening: define `window.gm_authFailure` in `official_map.js` to show a visible error and always render the existing marker *list* fallback, so a blocked key degrades gracefully instead of a blank rectangle.

Phase 1 — Map-first landing + pin markers + mobile detail

Headline value, low risk, no dependency on auth.

- `blueprints/official.py`: add `home()` on `/` that redirects to `map_view`; move the dashboard body to `/dashboard` but **keep the endpoint name `dashboard`** (nav uses it). Pass `active="map"|"dashboard"|"planning"` to each template.
- `partials/_official_nav.html`: reorder so **Map is first**; add a **Logout** link. (The `active` highlight var is referenced but never passed today — start passing it.)
- `static/js/official_map.js` — in `loadAndRenderMarkers()`, keep all existing filter/color/click/poll/heatmap logic; replace only the marker `icon` from a circle to a **teardrop pin** symbol (urgency-colored, so critical/high render red/orange — matching the "red pins" ask while staying informative). Stay on `google.maps.Marker` (avoid `AdvancedMarker` — needs an extra library + Map ID).
- `static/css/official.css` — mobile-only (`max-width:640px`): dock the grievance modal as a **bottom sheet** (slide-up, rounded top, scrollable) and make the map fill the screen. Keep desktop unchanged. No JS change to the modal — the existing `<dialog>` works in the WebView.

Phase 2 — Authorities login (session, single shared passcode)

- `config.py`: add `OFFICIAL_PASSCODE` (from env, dev default); set cookie config for the cleartext WebView: `SESSION_COOKIE_SECURE=False`, `SESSION_COOKIE_SAMESITE="Lax"` (not "None"), `SESSION_COOKIE_HTTPONLY=True`, `PERMANENT_SESSION_LIFETIME=30 days`. `SECRET_KEY` stays stable.
- **New** `auth.py`: an `official_required` decorator — allow if session flag set; else return `401 JSON` for `/api/*` or redirect to login for page requests.
- `blueprints/official.py`: guard the pages; add `GET/POST /login` (constant-time passcode compare via `hmac.compare_digest`, set session, redirect to a *validated* next) and `GET /logout`.
- `blueprints/api.py`: add the guard to **only** `PATCH /api/grievances/<id>/status`. Leave citizen endpoints and all reads + `/uploads/*` open (the map markers, modal photos, citizen submit and chatbot all depend on them).
- **New** `templates/official/login.html`: a branded passcode card (no nav), native POST form.
- `.env`: add `OFFICIAL_PASSCODE`.

CSRF is intentionally skipped for the demo — single same-origin WebView client, `SameSite=Lax` already blocks the cross-site cookie vector, and the only protected mutation is a same-origin PATCH. Noted as a known limitation to revisit before any public deployment.

Phase 3 — Second native app (mobile-officials) via a fresh Capacitor project

A fresh project is chosen over duplicating the citizen `mobile/` dir because `cap add android` propagates the new appld into every generated file with zero stale-package build failures, and we're dropping plugins + changing the icon anyway.

- Author `mobile-officials/package.json` (only `@capacitor/core`, `@capacitor/android`, `dev @capacitor/cli` — **no camera/geolocation**, unused by officials), `capacitor.config.json` (`appId: org.peoplespriorities.authority`, `appName: "PP Authority"`, `server.url: http://192.168.1.5:5000/officials/`, `cleartext: true`), and a `www/index.html` stub.
- `npm install` then `npx cap add android` — generates the Android project with the authority appld everywhere.
- **Differentiate the icon:** copy the citizen icon family from `mobile/android/.../res/`, then change the background color from navy `#1e3a5f` to a distinct **authority green** `#0f5132` so the two launcher icons are visually distinct.
- Build + install: `npx cap sync android`, then `./gradlew assembleDebug`, then `adb install -r app-debug.apk`. Verify `adb shell pm list packages | grep peoplespriorities` shows **both** `.citizen` and `.authority`.
- No cookie collision between the two apps — separate Android sandboxes have separate WebView cookie stores even against the same origin.

Verification (end-to-end)

- Desktop: `/officials/` → bounces to login → wrong passcode rejected → correct passcode lands on the **map with pins**; click a pin → detail → change status → queue/map refresh. Logout returns to login.
- Confirm `PATCH .../status` returns 401 when logged out, and citizen submit + reads still work anonymously.
- Phone: launch **PP Authority** (distinct green icon) → login → map renders with pins over WiFi (this is where a referrer-restricted Maps key would show blank — Phase 0 must be done). Tap a pin → bottom-sheet → update status → citizen app / dashboard reflects it. Confirm the citizen app still opens to its own landing, unaffected.

Out of scope (deferred)

Per-user official accounts, department assignment, SLA tracking, bulk actions, push notifications. A single shared passcode is the agreed auth level.

Known fragility

The LAN IP `192.168.1.5` is hardcoded in both apps' `capacitor.config.json` **and** must be in the Maps key referrer allow-list; if the laptop's DHCP IP changes, update both and rebuild.